

Vulnerability Assessment Report

Portfolio Demonstration Notice

This report is a Portfolio Demonstration. It is a synthetic case study created for a cybersecurity consulting portfolio. It does not represent paid client work, employment history, or testing performed for a real organization.

No live third-party systems were tested. No real client names, production IP addresses, credentials, proprietary data, or sensitive information are included.

Executive Summary

This assessment reviews a synthetic small-business lab environment and demonstrates a practical vulnerability assessment workflow. The review identified four findings that are realistic for a lightly managed internal network: anonymous FTP access, legacy SMB exposure, outdated TLS support, and missing browser security headers.

The highest-priority issues are anonymous FTP access and SMBv1 exposure because they can increase the chance of data exposure, lateral movement, and remote service abuse. Remediation should focus first on removing unnecessary access, disabling legacy protocols, enforcing secure configuration baselines, and confirming changes with follow-up validation.

Assessment Scope

Item	Description
Assessment type	Portfolio vulnerability assessment case study
Environment	Synthetic internal lab network
Target profile	Small-business style network with common internal services
Testing depth	Discovery, service review, vulnerability validation, and reporting
Exclusions	No exploitation, credential attacks, social engineering, or live third-party testing

Methodology

1. Define scope and assessment boundaries.
2. Identify example assets and exposed services.
3. Review service configuration and common vulnerability patterns.
4. Validate findings using non-destructive evidence.
5. Assign severity using CVSS v3.1 where appropriate.
6. Map findings to MITRE ATT&CK techniques when the mapping supports realistic attacker behavior.
7. Recommend practical remediation steps.
8. Document findings in a consultant-style report.

Environment Summary

Asset	Role	Exposed Services
LAB-WEB-01	Internal web application host	HTTP, HTTPS
LAB-FILE-01	File sharing host	SMB
LAB-FTP-01	File transfer host	FTP

The asset names are synthetic and are included only to make the report readable.

Risk Summary

ID	Finding	Severity	CVSS v3.1	Priority
----	---------	----------	-----------	----------

	---		---		---		---		---	
	F-01		Anonymous FTP read access		High		7.5		1	
	F-02		Legacy SMBv1 exposure		Critical		9.8		2	
	F-03		TLS 1.0 and TLS 1.1 supported		Medium		5.9		3	
	F-04		Missing HTTP security headers		Medium		4.3		4	

Findings

F-01: Anonymous FTP Read Access

```

**Severity:** High
**CVSS v3.1:** 7.5
**Vector:** `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`
**Affected asset:** LAB-FTP-01

```

Description

The FTP service allows anonymous read access. This creates a risk of unauthorized data disclosure if files are stored in exposed directories or if users place sensitive material on the service by mistake.

Evidence

- FTP service was identified on the lab file transfer host.
- Anonymous access was treated as enabled for this case study.
- No real files, credentials, or client data are included in this report.

Business Impact

Unauthorized users could retrieve exposed files without authentication. If the service contains business documents, exports, backups, configuration files, or internal notes, this could lead to confidentiality loss and follow-on attacks.

MITRE ATT&CK Mapping

	Technique		Name		Reason	
	---		---		---	
	T1083		File and Directory Discovery		Exposed file listings can help an attacker understand available data.	
	T1005		Data from Local System		Accessible files may be collected from the exposed service.	
	T1048		Exfiltration Over Alternative Protocol		FTP can be used as a transfer channel for collected data.	

Remediation

- Disable anonymous FTP access.
- Replace FTP with SFTP or another encrypted file transfer method.
- Restrict file transfer access to named users with least privilege.
- Review exposed directories and remove files that do not need to be shared.
- Monitor file transfer logs for unusual access patterns.
- Retest the service after configuration changes.

F-02: Legacy SMBv1 Exposure

```

**Severity:** Critical
**CVSS v3.1:** 9.8
**Vector:** `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`
**Affected asset:** LAB-FILE-01

```

Description

The file sharing host is modeled with SMBv1 enabled. SMBv1 is an outdated protocol and should not be used in modern environments. Legacy SMB exposure increases the likelihood of remote service exploitation, lateral movement, and data access if other weaknesses are present.

Evidence

- SMB file sharing was identified on the lab file host.
- SMBv1 exposure was included as a realistic configuration weakness.
- No exploitation was performed.

Business Impact

An attacker who can reach the service may attempt to exploit known SMB weaknesses or use the service during lateral movement. Successful compromise could affect confidentiality, integrity, and availability of shared data.

MITRE ATT&CK Mapping

Technique	Name	Reason
T1210	Exploitation of Remote Services	SMB services are common targets for remote exploitation attempts.
T1021.002	Remote Services: SMB/Windows Admin Shares	SMB can be used for lateral movement after access is obtained.

Remediation

- Disable SMBv1 on all systems.
- Require SMBv2 or SMBv3 where file sharing is needed.
- Apply current operating system and security updates.
- Restrict SMB access with host firewall rules and network segmentation.
- Review share permissions and remove broad access.
- Validate that SMBv1 is disabled after remediation.

F-03: TLS 1.0 and TLS 1.1 Supported

****Severity:**** Medium
****CVSS v3.1:**** 5.9
****Vector:**** `CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N`
****Affected asset:**** LAB-WEB-01

Description

The web service is modeled as supporting TLS 1.0 and TLS 1.1. These protocols are deprecated and should be disabled. Modern services should use TLS 1.2 or TLS 1.3 with secure cipher suites.

Evidence

- HTTPS was identified on the lab web host.
- Legacy TLS support was included as a realistic web configuration issue.
- No interception or sensitive traffic testing was performed.

Business Impact

Legacy TLS support can weaken transport security and may expose users to downgrade or interception risks under certain network conditions. It can also create compliance issues for organizations that require modern encryption standards.

MITRE ATT&CK Mapping

Technique	Name	Reason
T1040	Network Sniffing	Weak transport security can increase exposure if traffic is captured.
T1557	Adversary-in-the-Middle	Legacy protocol support can increase risk during interception scenarios.

Remediation

- Disable TLS 1.0 and TLS 1.1.
- Enable TLS 1.2 and TLS 1.3 where supported.
- Remove weak cipher suites.
- Use a trusted certificate from an approved certificate authority.
- Test the service after changes with a TLS configuration scanner.

F-04: Missing HTTP Security Headers

****Severity:**** Medium
****CVSS v3.1:**** 4.3
****Vector:**** `CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:N/A:N`
****Affected asset:**** LAB-WEB-01

Description

The web service is modeled as missing common browser security headers. Missing headers do not confirm an exploitable vulnerability by themselves, but they reduce browser-side protections and can increase impact if other web weaknesses exist.

Evidence

- HTTP and HTTPS services were identified on the lab web host.
- Missing security headers were included as a realistic hardening gap.
- No application exploitation was performed.

Business Impact

Users may have less protection against clickjacking, content injection, MIME sniffing, and unsafe browser behavior. The practical risk depends on the application design and other vulnerabilities present.

MITRE ATT&CK Mapping

There is no precise direct MITRE ATT&CK technique for missing HTTP security headers alone. This finding is best treated as a web hardening issue that can increase the impact of other web application vulnerabilities.

Remediation

- Add `Content-Security-Policy` appropriate to the application.
- Add `X-Frame-Options` or use the CSP `frame-ancestors` directive.
- Add `X-Content-Type-Options: nosniff`.
- Add `Referrer-Policy`.
- Add `Strict-Transport-Security` after HTTPS is fully configured.
- Test headers in a staging environment before production rollout.

Remediation Roadmap

Priority	Action	Owner Type	Target Timeline
1	Disable anonymous FTP and migrate to authenticated encrypted transfer	System administrator	1 week

2	Disable SMBv1 and restrict SMB access	System administrator	1 week
3	Disable TLS 1.0 and TLS 1.1; update cipher configuration	Web administrator	2 weeks
4	Add missing HTTP security headers and test application behavior	Web administrator	2 weeks
5	Retest all findings and document closure evidence	Security analyst	30 days

Validation Plan

- Confirm anonymous FTP access is disabled.
- Confirm SMBv1 is disabled and SMB access is restricted.
- Confirm only TLS 1.2 and TLS 1.3 are accepted.
- Confirm weak ciphers are not supported.
- Confirm expected HTTP security headers are present.
- Capture before-and-after evidence for each remediated finding.

Limitations

This report is a portfolio case study and does not include production scanning data, authenticated testing, exploit validation, malware analysis, or review of a real organization's policies. Findings are realistic examples selected to demonstrate consulting report structure and risk-based remediation.

Conclusion

The synthetic environment contains common configuration weaknesses that can create meaningful risk if present in a real network. The recommended remediation steps are practical, low-complexity actions that reduce exposure, improve service hardening, and create a stronger baseline for future security operations.